PRESIDIO

v0.29.0

USER MANUAL

IKI-Gov Assess

A governance policy describes a process; an auditor asks for a decision. IKI-Gov Assess turns the IKI-Gov reference model into decisions you can record, enforce and hand over: which AI use case, which gate, on what evidence, signed by whom.

This manual covers version 0.29. It takes you from installation to a signed gate certificate in nine short steps.

---

1. What the tool decides

The IKI-Gov model follows an AI system through seven lifecycle phases: context, concept, development, release, operation, adaptation and decommissioning. Six quality gates, G0 to G5, sit between them. A use case passes a gate when the checklist items that gate depends on are in place.

You answer 25 checklist items. Each answer feeds one of six measurement dimensions, M1 to M6, and one or more gates. The tool returns a maturity score per dimension and a status per gate: OPEN, PARTIAL or BLOCKED.

The score tells you how far you are. The gate tells you whether you may proceed. Read the gate first.

---

2. Install

The tool needs Python 3.10 or later.

```
pip install presidio-hardened-ikigov-assess
pip install "presidio-hardened-ikigov-assess[crypto]"   # Ed25519 signatures
pip install "presidio-hardened-ikigov-assess[audit]"    # startup CVE check
iga --version
```

On every start the tool checks its own dependencies for known vulnerabilities. Offline or in CI, switch the check off with `iga --no-dep-check <command>`.

---

3. Run your first assessment

Start with the wizard. It asks the 25 questions in turn, grouped by section.

```
iga assess --interactive --use-case credit-scoring --risk-class high
```

Once you know the items, pass the answers directly. An item you affirm counts as in place. An item you skip counts as not yet assessed. An item you leave out counts as denied, and a denied item blocks every gate it belongs to.

```
iga assess --use-case credit-scoring --risk-class high --lang en \
    --affirm S1,S2,S3,S4,S5,D1,D2,D4,D5,T1,T2,T3,T4,O1,O2,O3,I1 --skip D3
```

The appendix lists all 25 items with their dimension and gates.

---

4. Read the result

The output has two blocks. The dimension block shows six bars, one per measurement dimension, and the overall maturity as their mean. The gate block shows each gate with its status and the items that hold it back.

For the example above the overall maturity is 71.7 %. G0 and G1 are OPEN. G2 is BLOCKED because the skipped licence check D3 is not permitted at high risk. G3 to G5 are BLOCKED by items that were never affirmed.

The risk class decides what a skip costs:

RISK CLASS	A SKIPPED GATE ITEM	GATE STATUS
`low`	forgiven	OPEN
`medium`	tolerated until affirmed	PARTIAL
`high`	not permitted	BLOCKED

Add `--strict` to apply the high-risk rule at any risk class. The same assessment at medium risk turns G2 from BLOCKED into PARTIAL, which shows why the risk class belongs in the record.

---

5. Enforce a gate in CI

A gate earns its name when a pipeline can stop on it. The `gate` command checks one gate and, with `--assert-gate`, returns an exit code a pipeline can branch on.

```
iga --no-dep-check gate --gate G2 --risk-class high \
    --affirm S1,S2,D1,D2,D3,D4,D5,T1,T2,T3 --assert-gate G2
```

EXIT CODE	MEANING
0	gate OPEN
2	gate PARTIAL
3	gate BLOCKED
1	invalid input or other error

Add `--quiet` for JSON output. Keep the answers in a file under version control, and every change to a gate decision becomes a reviewed commit.

---

6. Produce reports and evidence packs

For a person, write a Markdown report. For a machine, write JSON.

```
iga report --use-case credit-scoring --affirm S1,S2,T4 \
    --output audit/credit-scoring.md
iga report --use-case credit-scoring --affirm S1,S2 \
    --format json --output credit-scoring.json
```

For an auditor, export an evidence pack. The pack holds both reports and a manifest with the SHA-256 hash of each file and of the framework version that produced it. Seal the manifest with a key file, so the key stays out of your shell history.

```
iga export --use-case credit-scoring --risk-class high --affirm S1,S2,D1 \
    --bundle audit/credit-scoring/ --sign-key-file ~/.iga/seal.key
iga verify-bundle --bundle audit/credit-scoring/ \
    --sign-key-file ~/.iga/seal.key
```

Change one byte in the pack and `verify-bundle` names the file and exits with 1.

---

7. Map the result to a regulation

The same answers produce three regulatory views. None of them asks a new question.

```
iga iso-gap --use-case credit-scoring --risk-class high \
    --affirm S1,S2,S3,I1,I2
iga euaiact-gap --use-case credit-scoring --affirm S1,S2,S3,S4,S5,D1,D5
iga framework-gap --framework nist-ai-rmf --affirm S1,S2,S3
```

The ISO/IEC 42001 view reports each clause as covered, partial or gap and lists the missing items. The EU AI Act view applies to high-risk systems only and reports Articles 9 to 18 and 72 as OPEN, PARTIAL or BLOCKED, based on the gates that produce their evidence. Frameworks ship as versioned content packs; `iga content-list` shows the installed ones and their hashes.

These views orient a team. They are not legal advice and not a conformity assessment.

---

8. Replace assertions with evidence

A tick in a checklist proves that someone typed it. Under `--require-evidence` an item counts only when a signed evidence reference for it verifies against your trust store.

```
iga assess --use-case credit-scoring --risk-class high \
    --evidence evidence.json --trust trust.json --require-evidence
```

The trust store maps each signer to an HMAC secret or an Ed25519 public key; a list of keys lets an old and a new key overlap during rotation. Verification is fail-closed. A missing signature, an unknown signer or a wrong key verifies nothing, and an item that rests on a bare `--affirm` shows up as "asserted (not counted)".

To issue a decision that others can check without you, sign a gate certificate. Generate the issuer key once; the command prints the trust-store entry that verifiers need.

```
iga workshop keygen --out issuer.key --signer presidio-assessor --lang en

iga certify --gate G2 --use-case credit-scoring --risk-class high \
    --affirm S1,S2,D1,D2,D3,D4,D5,T1,T2,T3 \
    --issuer presidio-assessor --sign-alg ed25519 \
    --sign-key-file issuer.key --valid-days 90 --output cert.json
iga verify-certificate --certificate cert.json --trust trust.json
```

The certificate carries the answers, the embedded evidence and the decision rule. The verifier recomputes the decision from the certificate alone: no database, no engine, no network. It proves that the decision follows from the declared inputs; it does not prove that the controls behind them work.

---

9. Track a portfolio

Add `--save` to keep an assessment in a local SQLite file at `~/.iga/assessments.db`, readable by your user account only.

```
iga list
iga portfolio
iga trend --use-case credit-scoring
iga delete --use-case credit-scoring
```

`portfolio` averages the latest run of every use case and counts the blocked gates. `trend` compares two runs and shows which gates opened or closed. `delete` removes every run for the use case and keeps no copy.

Workshops and agents

Two more entry points share the same engine. `iga workshop run` drives a customer workshop on an offline laptop: it projects each use case and writes a leave-behind that the customer signs with their own key. `iga-mcp` exposes the assessment as a Model Context Protocol server, so an AI agent can check a gate before it acts. The README documents both.

Where to get help

Report bugs on GitHub at presidio-v/presidio-hardened-ikigov-assess. Report vulnerabilities privately to security@presidio-group.eu, as described in SECURITY.md. For workshops and assessments, write to office@presidio-group.eu.

Appendix: the 25 checklist items

Generated from the checklist in the installed package. The last column names the measurement dimension and the gates each item feeds.

ID	ITEM	FEEDS
S1	A documented business objective and measurable success criteria exist for this AI use case.	M1 · G0, G1
S2	An accountable business owner is identified and has formally committed to this use case.	M1 · G0, G1
S3	The organisation's AI governance strategy explicitly covers this use case and names the responsible governance body.	M1 · G0, G1
S4	A stakeholder map identifying all affected parties — including impacted individuals, regulators, and internal decision-makers — has been documented and reviewed.	M1 · G1
S5	The expected value and the risk-benefit trade-off of deploying this AI system are documented and approved by the responsible governance body.	M1 · G1
D1	All data sources are inventoried and data lineage is documented end-to-end back to the origin.	M2 · G1, G2
D2	A data quality assessment covering completeness, accuracy, and timeliness has been conducted, documented, and identified deficiencies addressed.	M2 · G2
D3	Usage rights and licences for all data sources have been legally verified, are fully documented, and cover the intended use purpose.	M2 · G2

ID	ITEM	FEEDS
D4	A Data Protection Impact Assessment (GDPR Art. 35 / DSGVO) has been completed, reviewed by the data protection officer, and identified risks mitigated.	M2 · G2
D5	An ethical risk assessment — including evaluation of discrimination and fairness risks — has been documented and reviewed by the responsible governance body.	M2 · G1, G2
T1	Model validation against a held-out test set is documented including performance metrics (accuracy, precision, recall, AUC, or equivalent) and meets the agreed thresholds.	M3 · G2, G3
T2	Fairness checks across relevant protected groups (e.g. gender, age, origin) have been performed, results are documented, and identified disparities addressed.	M3 · G2
T3	An explainability mechanism (e.g. SHAP, LIME, rule extraction) is implemented, tested, and its outputs are documented in a form interpretable by the relevant stakeholders.	M3 · G2, G3
T4	Adversarial robustness tests and strict input validation together with output sanitisation are implemented, tested, and results documented.	M4 · G3
T5	A security review of the model pipeline, infrastructure, and all dependencies (including third-party components) has been conducted and findings addressed.	M4 · G3
O1	A production monitoring dashboard covering AI-relevant KPIs (model performance, data drift, system availability) is operational and actively monitored.	M6 · G3, G4
O2	Data and model drift detection with automated alerting is configured, tested, and responsibilities upon alert triggering are defined.	M6 · G4
O3	A human oversight process for AI system decisions — including escalation paths and override capabilities — is defined, documented, and tested.	M6 · G3, G4
O4	An incident response and change management procedure for the AI system is established, documented, and validated through a drill or real incident.	M6 · G4

ID	ITEM	FEEDS
O5	An audit log — capturing model decisions, significant events, and parameter changes — is maintained, stored immutably, and accessible to authorised auditors.	M6 · G4, G5
I1	An AI management system policy aligned with ISO/IEC 42001 clause 5.2 is documented, approved by top management, and communicated organisation-wide.	M5 · G4, G5
I2	Roles and responsibilities for AI governance per ISO/IEC 42001 clause 5.3 are formally defined, assigned, and communicated organisation-wide.	M5 · G4, G5
I3	An AI risk register per ISO/IEC 42001 clause 6.1 is maintained, reviewed at defined intervals, and linked to the overarching governance process.	M5 · G5
I4	The AI system lifecycle is documented in line with ISO/IEC 42001 clauses 8.3–8.6, covering development, operational, and decommissioning phases.	M5 · G5
I5	An internal audit of AI governance activities per ISO/IEC 42001 clause 9.2 has been conducted, findings documented, and corrective actions initiated.	M5 · G5

© PRESIDIO OOD · Sofia, BG